学生成绩管理系统 · 全项目审计报告

- **审计对象**：`D:\r\StudentScoreSystem`
- **技术栈**：Spring Boot 3 + MyBatis-Plus + PostgreSQL + JWT（后端，202 个 Java 文件）；Vue 3 + Vite + Element Plus + Pinia + Axios（前端，40+ 个 `.vue`）
- **审计日期**：2026-10-02
- **审计方式**：分模块静态审计（后端安全/鉴权、后端业务逻辑与数据一致性、数据库与 SQL、前端、部署与配置），**未运行构建或测试**
- **基线提交**：`2445469`（HEAD）

严重等级说明

等级	含义
🔴 严重	可直接导致敏感数据泄露、越权、数据丢失或不可逆损坏，需立即处理
🟠 高	明显安全或正确性缺陷，有实际利用/触发场景
🟡 中	健壮性、性能、一致性问题，随数据量或并发增长而恶化
🔵 低	代码质量、规范、可维护性问题

> ⚠️ 本报告为静态代码审计结论，部分条目（尤其是并发与运行时行为）建议在修复前先复现确认。

一、执行摘要

本次审计共发现 **严重 11 项、高 20 项、中 30+ 项、低 20+ 项**。最需要优先处理的几类风险：

1. **敏感数据泄露（🔴）**：`/user/student-list` 等接口只需合法 Token 即返回完整 `SysUser`，且 `SysUser.password`（BCrypt 哈希）无 `@JsonIgnore`，任意登录用户可批量获取全体学生密码哈希、手机号、邮箱。
2. **大面积垂直/水平越权（🔴）**：成绩管理、成绩审核、账号禁用/启用/新建、待审列表等多处接口**完全没有角色或归属校验**，任意学生可审批加分、作废他人成绩、禁用账号。前端路由权限也被 `localStorage` 角色欺骗绕过。
3. **生产密钥已泄露（🔴）**：`generator/CodeGenerator.java` 硬编码真实数据库口令 `jinru20070507` 且已被 git 跟踪。
4. **多步写操作无事务（🔴）**：审核、规则同步、终审等流程"先写 A 再写 B"且无 `@Transactional`，失败即产生永久脏数据。
5. **不可逆的数据库迁移（🔴）**：`score_rule` 迁移先 `ADD score_type` 再 `DROP COLUMN category`，**全程无数据回填**，历史规则数据永久丢失且每次部署重复执行。

6. **重复计分（🔴）**：审核幂等校验的 `sourceType` 常量与写入值不一致，防重逻辑永远失效，同一申请可被重复加分；终审为无锁的 count-then-insert 竞态。

二、🔴 严重问题清单（跨模块汇总）

#	位置	问题
S1	`.../controller/UserInfoController.java:46-95` + `entity/SysUser.java:53`	`/user/student-list` 无管理员校验，返回含 `password`（BCrypt 哈希）的 `SysUser` 列表
S2	`.../controller/ScoreRecordAdminController.java:50-199`	`/admin/scoreRecord/**` 三个接口无角色校验，任意学生可读他人成绩、作废/恢复成绩
S3	`.../controller/ScoreAuditController.java:143-282`	`/scoreAudit/audit`、`/pending` 未校验审核岗位，任意学生可审批加分、查看全部待审
S4	`.../controller/SysUserController.java:896-967,979+`	`/user/student/disable
S5	`.../generator/CodeGenerator.java:21`	硬编码真实数据库口令 `jinru20070507`，文件已被 git 跟踪
S6	`.../controller/ScoreAuditController.java:308-319 vs 375`	幂等校验读 `"SCORE_APPLY"`、写入 `"APPLY"`，防重永久失效，可重复加分
S7	`.../controller/ScoreAuditController.java:143-473`	`audit()` 无事务，串行 5 处写，失败即脏数据
S8	`.../controller/ScoreAuditController.java:343-419`	`applyScore` 为 null 触发 NPE，且此前申请状态已提交为"通过"
S9	`.../controller/ScoreRuleController.java:150-158 / 218-230 / 289-297`	规则落库与模板同步无事务，异常时两边不一致
S10	`.../controller/ScoreApplyController.java:1956-2052`、`DepartmentScoreApplyController.java:2397-2421`	终审 count-then-insert 无锁无唯一约束，并发重复生成成绩
S11	`sql/02_create_table.sql:580-584`	`DROP COLUMN category` 无回填，历史规则 `score_type` 永久为 NULL
S12	`frontend/src/router/index.js:587-706,774-851`	前端权限判断形同虚设（学生即放行 / 角色取自可篡改的 `localStorage`）
S13	`frontend/src/views/Login.vue:154-166` + `layout/MainLayout.vue:431`	token 存入 `localStorage` 且被 `console.log` 打印，易被窃取

三、🛡️ 后端安全与鉴权

严重

- **`UserInfoController.java:46-95`** — `/user/student-list` 只要 Token 合法即返回 `Result<List<SysUser>>`（L95），而 `SysUser.java:53` 的 `password` 无 `@JsonIgnore` → **全体学生 BCrypt 哈希、手机号、邮箱泄露**。建议：返回 `StudentVO`，并在 `SysUser.password` 加 `@JsonIgnore`（或全局忽略）。
- **`ScoreRecordAdminController.java:50-75, 81-137, 143-199`** — `/admin/scoreRecord/**` 三个接口无角色校验，`getUserId` 仅判空（L104、L166）。
- **`ScoreAuditController.java:143-282`** — 仅 `auditorId != null`（L155-160）确认登录，未校验审核岗位。
- **`SysUserController.java:896-926, 937-967, 979+`** — 禁用/启用/新建学生无管理员校验（对比 L1206 `reset-password` 有校验）。

高

- **`LoginController.java:161-199`**、**`PasswordController.java:163-179`** — 仍兼容明文口令：非 BCrypt 前缀时用 `String.equals` 比对（非恒定时间，存在计时侧信道）。
- **`SysUserController.java:75-80, 517-522, 696-701`** — `student/list`、`student/all`、`student/search` 无管理员校验，可枚举全体学生。
- **`WebConfig.java:39-53`** — 授权仅靠 `JwtInterceptor`（认证）+ `@RequireRole`（仅 8 个 Controller 使用，`RequireRole.java:7` 仅支持方法级），大量写接口处于"仅需登录"状态。建议引入 Spring Security + `@PreAuthorize`。

中

- **`LoginController.java:31-33, 109-112, 415-422`** — 防爆破按 username 计锁且无清理：可对已知用户名发起 5 次失败锁定账号（DoS）；`failures` 为无界 `ConcurrentHashMap`，内存可被撑大；无 IP 限速。
- **`JwtConfiguration.java:15-16`** vs **`utils/JwtUtil.java:11-14`** — 校验读 `${jwt.secret}`，签发却读 `System.getenv("JWT_SECRET")`，两套来源不一致。
- **`JwtUtil.java:41-57`** — 无 `jti` / `issuer` / `audience`，未显式指定 HS256；Token 固定 24h，改密/禁用后旧 Token 仍有效，无登出失效机制。
- **`JwtInterceptor.java:74-109`** — 支持从 Cookie 取 Token，配合 `CorsConfig.java:14` 的 `allowCredentials(true)`，若 Cookie 无 `SameSite` / `HttpOnly` 存在 CSRF 风险；而 `RoleInterceptor.java:96-118` 只读 `Authorization` 头，两处逻辑不一致。
- **`RoleInterceptor.java:182-239`** — `selectOne`（L183）对多岗位用户抛 `TooManyResultsException` 返回 500；`position.getName().equals(...)`（L238）null 时 NPE；多岗位仅取一条。
- **`PasswordController.java:102-114`**、**`SysUserController.java:1280`** — 口令仅校验长度 6-50，无复杂度要求；重置口令固定 `123456`。
- **全局** — `pom.xml:100-104` 仅引入 `spring-security-crypto`，无 `spring-boot-starter-security`（无 CSRF 防护、无安全响应头）；`application.yml:30` 开启 `StdOutImpl`，生产打印含敏感数据的 SQL。

低

- **`CorsConfig.java:11-15`** — 允许来源硬编码 `http://localhost:5173` 与公网隧道 `https://frp-box.com:25848`，配合 `allowCredentials` 存在凭据泄露风险。
- **`JwtInterceptor.java:188`** — 异常时 `e.printStackTrace()`。
- **`application.yml:6`** — `DB_PASSWORD` 默认空串。
- **`UserInfoController.java:117`** — `token.replace("Bearer ","")` 未判空。
- ✅ **`GlobalExceptionHandler.java:17-35`** — 日志记录完整异常、对外仅返回通用话术，处理得当。

> 说明：`ActivityArchiveController`、`ActivityController`、`SysDepartmentController` 等 11 个 Controller 为仅含 `@RequestMapping` 的空类，无实际接口；`DepartmentScoreTemplateController`、`ScoreApplyController` 已实现部门/岗位归属校验。

四、🧩 后端业务逻辑与数据一致性

> 路径相对 `student-score-system/src/main/java/com/student/studentscoresystem/`（下表记作 `~/`）

严重

1. **`~/controller/ScoreAuditController.java:308-319`** — 幂等校验读 `sourceType="SCORE_APPLY"`，写入为 `"APPLY"`（L375），**防重永不生效**，同一申请反复审核会重复生成 `ScoreRecord` / `ScoreFlow`。建议统一常量并在 `score_record(source_type, source_id)` 建唯一索引。
2. **`~/controller/ScoreAuditController.java:143-473`** — `audit()` 无 `@Transactional`，串行 5 处写：audit（L264）→ apply 状态（L272-282）→ record（L387）→ flow（L456）→ 通知（L539），任一步失败即永久不一致。
3. **`~/controller/ScoreAuditController.java:343-419`** — `applyScore` 为 null 时 NPE（L353 使用、L417-418 再次 `subtract`），而 apply 状态已提交为"通过"。
4. **`~/controller/ScoreRuleController.java:150-158 / 218-230 / 289-297`** — 规则落库与 `DepartmentTemplateSyncService` 同步无事务。
5. **`~/controller/ScoreApplyController.java:1956-1978, 2040-2052`** — `finalAudit` 先 count 再 insert，无锁无唯一约束，并发终审重复生成证书成绩；且未生成 `ScoreFlow`（与 `ScoreAuditController` 不一致）。
6. **`~/controller/DepartmentScoreApplyController.java:2397-2421`** — 部门终审同样是 count-then-insert 竞态（L2495-2548 按 title 匹配规则）。

高

7. **`ScoreAuditController.java:143-230`** — 审核仅校验"不能审自己"（L222-230），无角色/权限校验。
8. **`ScoreAuditController.java:357-359`** — `record.setSemesterId(1L)` 硬编码学期，成绩永远落在 1 号学期。
9. **`service/impl/ScoreStatisticsServiceImpl.java:36`** — `score.compareTo(...)` 未判空，NPE。
10. **`ScoreStatisticsServiceImpl.java:44-52`** — `total = 40 + bonus - deduct` 与其余入口的 `total = min(bonus, 40 - deduct)` 不一致，且不过滤学期 → 统计错误。
11. **`ScoreRuleController.java:433-442`** — 同名规则 count 后插入，无唯一约束，可产生同部门同名规则，终审按"部门+名称"匹配产生歧义。

中

12. **`service/ScoreProjectNameResolver.java:390`** — `departmentMapper.selectBatchIds(departmentIds)` 中 `departmentIds` 实际存的是 `DepartmentScoreApply.id`（L259-263），导出时"部门-标题"前缀恒为空。
13. **`ScoreRecordController.java:494-537`** — `convertVO` 每条调用 `resolve()`（内部 `selectById`）→ N+1；**`AdminScoreController.java:81-100`** 每条再调 `resolve` + `resolveSourceLabel`（2 次查询）→ N+1。建议改用 `preload` 批量预取。
14. **`ScoreRecordController.java:168-178`** — `list()` 一次性加载全部成绩（无分页），叠加 N+1。
15. **`AdminScoreController.java:109-180`** 与 **`ScoreRecordController.java:293-439`** — hide/restore "查状态→改→写日志"，无事务、无乐观锁，且两套端点重复。
16. **`AdminScoreController.java:222-265`** — 成绩更正未校验 `newScore` 范围（可为负/超上限），整实体 `updateById` 会覆盖并发改动。
17. **`DepartmentScoreApplyController.java:2470-2548`** — 终审用 `apply.getTitle()` 精确匹配 `score_rule.name`，规则改名后匹配不到，被当作"非固定活动"按申报值生成成绩，绕过"分值须等于规则分值"校验。建议改用 `rule_id` / `template_id` 关联。
18. **`DepartmentScoreApplyController.java:1810-1838`**（batchPass 循环 selectOne）与 **L2727-2800**（fillNames 每条最多 3 次 selectById）— N+1。
19. **`service/impl/ExcelImportServiceImpl.java:82/480/1163`** — Excel 解析在 `@Transactional` 方法内执行；`importStudents` 循环内每行 2 次 select + 写（L294-462），大文件长时间占用连接/事务。
20. **`ExcelImportServiceImpl.java:414`** — `updateById`（L459 `insert`）返回值被忽略仍 `successCount++`，失败被计为成功。
21. **`DepartmentScoreApplyController.java:573-585`** — 学生申报查重为 count 后 save，无事务/唯一约束；**`ScoreApplyController.java:360-853`** 证书申报无任何查重。
22. **`AdminScoreController.java:187-220`** 与 **`ScoreRecordController.java:215-228`** — 统计/明细仅过滤 `adminHidden`，未过滤 `status`、未按学期；而导出（`ScoreExportServiceImpl.java:370-391`）过滤 `status` 且按学期 → 同一学生"总分"口径不一致。

低

23. **`DepartmentScoreApplyController.java:2349-2375, 2627-2712, 699-741, 823-830`** — 大量 `System.out.println`。
24. **`ScoreApplyController.java:749, 846`** — `e.printStackTrace()`。
25. **`service/ScoreProjectNameResolver.java:687-696`** — `readJson` 吞掉所有异常返回 null。

五、🗄️ 数据库与 SQL

> 范围：`sql/01~04`、`entity/` 28 个实体。`sql/04_init_data.sql` 为 0 字节空文件。

严重

- **`sql/02_create_table.sql:580-584`** — 迁移块先 `ADD COLUMN score_type` 再 `DROP COLUMN IF EXISTS category`，**全程无回填**（全仓库无 `UPDATE score_rule SET score_type`）。`category` 是唯一原始来源，删除后历史规则 `score_type` 全为 NULL，而代码强校验 `score_type ∈ {1,-1}`

（`ScoreRuleController.java:413-419`、`ExcelImportServiceImpl.java:1326-1335`）→ **历史规则无法编辑/统计，数据永久丢失**。且 `deploy.yml:120-122` 每次部署都执行该脚本并 `ON_ERROR_STOP=1`，`DROP COLUMN` 反复执行、不可逆。

- **`sql/02_create_table.sql:575-576 vs 581`** — 注释声明"不会删除、不会覆盖任何数据"，但 L581 实际 `DROP COLUMN`，注释与行为矛盾。
- **`sql/02_create_table.sql:429-440, 443-455`** — `department` 用 `CREATE TABLE IF NOT EXISTS` 携带 `pk_department` / `uk_department_name` / `ck_department_status`；表已存在时这些 PK/UNIQUE/CHECK **不会被补建**（DO 块只补了列）。同缺陷见 `sys_user_department`（464-495）、`department_score_apply`（500-520）。

高

- **`sql/02_create_table.sql:362-370`** — `score` 表 `student_id`、`course_id` 无外键、无索引，可写入孤儿成绩。
- **`sql/02_create_table.sql:350-357`** — `course.teacher_id` 无 FK、无索引。
- **`sql/02_create_table.sql:586-590, 599-612, 632-651, 554-564`** — 补充的外键型列普遍无约束/索引：`score_rule.department_id`（有索引无 FK）、`score_apply.preliminary_reviewer_id/final_reviewer_id`、`department_score_apply.applicant_id/template_id/final_reviewer_id`、`department_score_template.department_id`（NOT NULL 却无 FK）。
- **唯一约束缺失**：`activity_student`（123-136，缺 `UNIQUE(activity_id, student_id)`）、`sys_user_position`（54-68）、`score`（362-370，缺 `UNIQUE(student_id, course_id, semester)`）、`department_score_template`（554-564，缺 `UNIQUE(department_id, name)`）、`sys_semester`（73-83，缺 `UNIQUE(name)`）。
- **FK 列普遍无索引**（PG 不自动建）：重点 `score_record(student_id, rule_id, semester_id)`、`score_apply(student_id, rule_id, status)`、`score_audit(apply_id)`、`notice_message(receiver_id)`、`operation_log(user_id)`。
- **`sql/04_init_data.sql:1`（空）** + 应用层弱口令：`SysUserController.java:1027, 1278`、`TeacherManageController.java:518`、`ExcelImportServiceImpl.java:321, 385`、`login.http:4-8`、`TeacherManage.vue:321` — 新库无种子账号；所有新建/重置账号同一弱口令 `123456`。
- **`sql/02_create_table.sql:28-37 vs 429-440`** — 存在两套部门表：`sys_department` 与 `department`（`sys_user_position.department_id` → `sys_department`，`sys_user_department.department_id` → `department`），实体并存 → 部门主数据双源。

中

- 所有 `update_time` 仅 `DEFAULT CURRENT_TIMESTAMP`，**无 ON UPDATE 触发器**，更新后不变化。
- **`sql/02_create_table.sql:511 vs 639`** — `department_score_apply` 同时有 `review_comment`（建表）与 `review_remark`（ALTER），实体用 `reviewRemark`，`review_comment` 为死列。
- **`sql/02_create_table.sql:393-405`** — `score_record_admin_log` 表无实体/Mapper，全仓库无引用。
- **`sql/02_create_table.sql:368 vs 224,235`** — `score.semester VARCHAR(50)` 与 `score_record.semester_id BIGINT` 建模不一致。
- **`sql/02_create_table.sql:367`** — `score.score INTEGER` 无法存储小数成绩。
- **`sql/02_create_table.sql:433,459`** — `department.department_type` 及 `idx_department_type` 全仓库未使用。

- **`sql/01_create_database.sql:19`** — `CREATE DATABASE` 无存在性判断与 `ENCODING`，非幂等。

低

- 约束存在性判断仅用 `pg_constraint.conname`，未限定 schema/table。
- `sys_position.status` 在 `Position.java`（Integer）与 `SysPosition.java`（Short）两种类型。
- `gender/status/score_type/source_type` 等枚举列多数无 CHECK。
- `sys_semester.start_date/end_date` 无先后校验。
- `score_apply.material_file VARCHAR(500)` 与 `department_score_apply.evidence_url VARCHAR(1000)` 长度不一致。
- `sql/03_table_comment.sql:1-80` 仅表级注释、缺多张表注释；L11 把 `sys_department` 注释为"部门组织表"（与实际新表 `department` 混淆）。
- `score_admin_adjustment`、`score_record_operation_log` 用显式 sequence + `"public".` 前缀，其余表用 `BIGSERIAL`，风格不一。
- `department_score_template` 建在 `COMMIT`（549）之后且无 FK/唯一约束。

六、🖥️ 前端

严重

- **`frontend/src/router/index.js:814-851`** — `requiresDepartmentLeader` / `requiresArchiveLeader` 仅判断 `role === '学生'` 即返回 `true`，任意学生可进入部门/证书审核页。
- **`frontend/src/router/index.js:774-807`** — `requiresArchiveExportPermission` 对 `role === '学生'` 直接放行，任意学生可访问汇总导出。
- **`frontend/src/router/index.js:587-706`** — 角色完全取自 `localStorage.user`（L589-590、691-692），可篡改为 `管理员` 绕过守卫进入 `/admin/*`。
- **`frontend/src/views/Login.vue:154-166`** — 整个 `res.data`（含 token）写入 `localStorage.user`；**`layout/MainLayout.vue:431`** 又 `console.log` 打印含 token 的对象 → 易被脚本窃取。

高

- **两套 axios 实例**：`utils/request.js:1-32`（有 unwrap/401 登出/15s 超时）与 `api/request.js:1-19`（无拦截器、无超时）；`api/` 下混用（`teacher/semester/score/adminScore/file` → `api/request`，`student/apply/login` → `utils/request`）→ 响应结构不一致、401 只覆盖一半、部分请求可能长期挂起。
- **`views/archive/ArchiveHome.vue:558-576, 713-730`** — 用 `@/utils/request`（已返回 `response.data`）却按未 unwrap 约定读取 `res.data?.code`，导出 `new Blob([res.data])` 为空 → 列表恒失败、导出为空文件（该文件未被路由引用，属死文件）。
- **`views/admin/TeacherManage.vue:253-256, 318-321, 457-460, 512-515`** 与 **`views/admin/StudentManage.vue:1412, 1426`** — 硬编码并明文展示默认弱口令 `123456`。

中

- **`api/request.js:3-7`** — 仅设 `baseURL`，无 `timeout`、无 401 拦截。
- **`nginx.conf:14-25`** — 缺 `X-Frame-Options` / `CSP` / `X-Content-Type-Options`，并主动 `proxy_set_header Origin ""`，削弱后端跨域校验。
- **`index.html:1-8`** — 无 CSP，`<html lang="">` 为空。
- **`vite.config.js:17-21`** — `host:'0.0.0.0'` 且 `allowedHosts:true`，对任意 Host 开放（DNS rebinding/隧道滥用）。
- **`src/main.js:13-43`** — 未调用 `createPinia()`，而 `stores/counter.js` 未被使用。
- **`views/Apply.vue:249-257, 715-723`** — `el-upload` 直连 `/api/file/upload` 并手写 `Authorization`，绕过统一请求。
- **`api/student.js:4-10` vs `api/adminScore.js:18-27`** — 同一端点 `/user/student/list` 定义两份且返回结构不同；`api/login.js` 与 `Login.vue` 直连 `/login` 重复。
- **`api/file.js:15-19`** — 上传到 `/fileInfo/upload`，后端实为 `/file/upload`，一旦调用必 404（当前为死代码）。

低

- 大量 `console.log` 打印用户对象与后端原始响应（`MainLayout.vue:431`、`Apply.vue:829-845`、`archive/ScoreExport.vue:133-172`、`Home.vue:628`）。
- 三套布局（`MainLayout` / `AdminLayout` / `TeacherLayout`）头部、移动端抽屉、响应式 CSS 大段复制。
- **`views/admin/RuleManage.vue:526-533`** — 提交携带 `status`，但后端 `ScoreRuleController.java:206-210` 更新忽略该字段，**规则启停实际不生效**。
- **`vite.config.js:10`** — `vueDevTools()` 无条件注册。
- **`views/Home.vue:654`** 用 `user.id`，`views/Score.vue:338` 用 `user.id || user.userId`；`Home.vue:662-664` 直接取 `res.data.data` 未兜底。

> 字段一致性：抽查后端字段均有对应（`scoreType`、`awardCategory`），未发现 `category` 遗漏。

七、🚀 部署、构建与配置

严重

- **`student-score-system/src/main/java/generator/CodeGenerator.java:21`** — 硬编码真实数据库口令 `jinru20070507`（L19 用户名 `postgres`），文件已被 git 跟踪 → **已发生泄露**。建议：立即轮换口令、改为 `System.getenv`、用 `git filter-repo`/BFG 清理历史、将该生成器移出主源码树。

高

- **镜像 tag 全部 `latest`**：`docker-compose.yml:3,24`、`docker-compose.prod.yml:3,19`、`deploy.yml:44,55` → 无法回滚/复现。
- **容器以 root 运行**：`frontend/Dockerfile:20,26`、`student-score-system/Dockerfile:18,26` 均无 `USER`。
- **无 `.dockerignore`**：`frontend/Dockerfile:12` `COPY . .` 会把宿主 `node_modules/`、`dist/` 等打进镜像。

- **`CorsConfig.java:12-14`** — 生产信任外部隧道域名 `https://frp-box.com:25848` 且 `allowCredentials(true)`。
- **`application.yml:30`** — `StdOutImpl` 无条件生效，生产打印全部 SQL 与参数。
- **`deploy.yml:102-107`** — 服务器上 `cat <<EOF > .env` 写入 `DB_PASSWORD`、`JWT_SECRET` 明文，未设 `umask` / `chmod`（默认 0644）。

中

- **`deploy.yml:102`** — `cat <<EOF`（未加引号分隔符），密钥含 `$`/反引号/`\` 会被展开，导致 `.env` 损坏或注入。
- **无 `healthcheck`**：`docker-compose.yml:29-30`、`docker-compose.prod.yml:24-25`，`depends_on` 无 `condition`，前端可能持续 502。
- **数据库容器未纳入编排**：两个 compose 均无 postgres 服务，仅靠 `deploy.yml:133` 动态 `docker network connect`，无数据卷/健康检查/备份。
- **`deploy.yml:130,133,136`** — 先 `up -d` 后端再连网再 `docker restart backend`，首启必连不上库。
- **无资源限制与日志轮转**：两个 compose 均无 `deploy.resources` / `mem_limit` / `logging.options`。
- **`frontend/nginx.conf:1-39`** — 无安全响应头，未 `server_tokens off`。
- **可变基础镜像 tag**：`frontend/Dockerfile:4,20`、`student-score-system/Dockerfile:4,18`。
- **`.gitignore:18`** — 仅忽略精确 `.env`，未覆盖 `.env.*`；`frontend/.gitignore` 无 `.env*`。
- **`docker-compose.yml:19`**、**`docker-compose.prod.yml:14`** — `./uploads:/app/uploads` 相对路径 bind mount。
- **`application.yml:6`** — `password: ${DB_PASSWORD:}` 默认空口令。

低

- `login.http:5-6`（已跟踪）与 `TeacherManage.vue:318,457`、`SysUserController.java:1027` 默认口令 `123456`。
- 容器未设时区（无 `TZ`），日志/定时任务为 UTC。
- **`student-score-system/Dockerfile:22,26`** — 无 JVM 内存参数、无 `HEALTHCHECK`。
- **`pom.xml:60-69`** — `mybatis-plus-generator`、`velocity-engine-core` 未设 `provided`。
- **`.gitignore:26`**（`*.sql`）— 通配忽略所有 SQL，未来新增迁移脚本会被静默排除。
- **`README.md:1-14`** — 无部署与密钥管理说明。

> ✅ `JWT_SECRET` 无默认值且启动强校验（`JwtConfiguration.java:23-28`，非空且 ≥32 字节），实现正确；frontend 仅绑定 `127.0.0.1:3080`，未对外暴露，符合预期。

八、修复优先级建议

第一优先级（立即，安全与数据）

1. 为 `SysUser.password` 加 `@JsonIgnore`，`/user/student-list` 等接口返回 VO 并补管理员校验（S1）。

2. 为 `ScoreRecordAdminController`、`ScoreAuditController`、`SysUserController` 的写/敏感读接口补齐角色与归属校验（S2/S3/S4）。
3. 轮换泄露的数据库口令，清理 git 历史，移除 `CodeGenerator` 硬编码（S5）。
4. 修复审核幂等常量不一致，并在 `score_record(source_type, source_id)` 建唯一索引（S6）。
5. 修正 `score_rule` 迁移：先回填 `score_type` 再删除 `category`（S11）。

第二优先级（本迭代）

6. 为审核、终审、规则同步等流程补 `@Transactional(rollbackFor = Exception.class)`，并将业务逻辑下沉到 Service（S7/S8/S9/S10）。
7. 统一计分口径（`min(bonus, 40 - deduct)`）、按学期过滤、修复硬编码学期 `setSemesterId(1L)`。
8. 前端统一为单一 axios 实例；路由权限改为后端返回的权限点，移除 `localStorage.user` 中的 token 与敏感 `console.log`。
9. 补齐数据库外键、唯一约束与索引。

第三优先级（持续改进）

10. 引入 Spring Security、密码复杂度与随机化初始口令、登录限速。
11. 部署：镜像固定 tag、容器非 root、`.dockerignore`、`healthcheck`、资源限制与日志轮转、`umask 077` 写 `.env`、将 postgres 纳入 compose。
12. 清理死代码/空控制器/废弃表（`score_record_admin_log`、`review_comment`、`ArchiveHome.vue` 等）。

九、审计方法与局限

- **方法**：按模块划分（后端安全、后端业务逻辑、数据库、前端、部署），对源码进行静态阅读与交叉引用；未执行编译、单元测试、集成测试或运行时验证。
- **局限**：
  - 未验证"数据库中是否已存在部分唯一索引/外键"——若已存在，业务逻辑章节中若干"并发重复插入"条目可降级为"缺少冲突处理"。
  - 并发类问题（S9/S10 等）为代码推理结论，需构造并发场景复现确认。
  - `CorsConfig` 中隧道域名 `frp-box.com:25848` 的归属未确认。
- **免责**：本报告仅覆盖所列举的静态代码证据，不构成完整渗透测试结论。